Combined US Operations of Banco Santander, S.A.

Technology



Secure Build and Configuration Management Standard

TABLE OF CONTENTS

1. INTRODUCTION 3
1.1 PURPOSE OF THIS DOCUMENT 3
1.2 SCOPE AND PERIMETER 3
1.3 DOCUMENT OWNERSHIP, APPROVAL, AND MAINTENANCE 3
2. GOVERNANCE AND ACCOUNTABILITY 4
2.1 Standard Governance 4
3. ROLES AND RESPONSIBILITIES 5
4. STANDARD 6
4.1 STANDARD OVERVIEW 6
4.2 STANDARD REQUIREMENTS 6
4.2.1 Lifecycle Requirements 6
4.2.2 Standard Requirements 8
4.2.3 Implementation Process Requirements 10
4.2.4 Device Management Requirements 12
4.2.5 Policy as Code Requirements 12
5. REPORTING STRUCTURE AND ESCALATION 13
6. EXCEPTIONS 13
7. DOCUMENT HISTORY AND VERSION CONTROL 14
7.1 OWNERSHIP AND AUTHORSHIP 14
7.2 SIGN OFF 14
7.3 SUBSIDIARY SIGN OFF 15
8 APPENDIX 16
8.1 APPENDIX A – KEY CONTACTS 16
8.2 APPENDIX B – REGULATORY OBLIGATIONS ADDRESSED BY THIS STANDARD 16
8.3 APPENDIX C – GLOSSARY 17
8.4 APPENDIX D – RELATED POLICIES AND PROCESS AND ADMINISTRATIVE DOCUMENTS 19

1. INTRODUCTION

1.1 Purpose of this Document

The Secure Build and Configuration Management Standard (this "Standard") establishes the minimum mandatory requirements for securely building, configuring, and maintaining Combined US Operations of Banco Santander, S.A. ("CUSO")-managed technology assets throughout their lifecycle. It applies to all CUSO in-scope corporate devices, including end-user devices, servers, infrastructure components, and cloud-hosted assets managed by or on behalf of Santander.

This Standard outlines governance and control expectations for secure configuration baselines, hardening, configuration monitoring, exception management, and policy-as-code implementation aligned with information security and operational standards. The objective of this Standard is to reduce configuration-related security risks, ensure consistent and auditable secure builds, and support the confidentiality, integrity, availability, and resilience of CUSO technology environments.

1.2 Scope and Perimeter

This Standard applies to CUSO, including the business units operating through Santander Holdings USA, Inc. ("SHUSA") and its subsidiaries (individually, "Subsidiary," collectively, "Subsidiaries," and together with SHUSA, "Santander US") and the Banco Santander, S.A. New York Branch ("BSNY") first line of defense functional areas within the Technology division. Additional requirements that are specific to an individual Subsidiary can be found in the Exceptions section of this Standard. Operating policies and/or standards developed by the Subsidiaries must comply with the requirements set forth in this Standard.

The scope of this standard covers Corporate Devices.

1.3 Document Ownership, Approval, and Maintenance

This Standard is categorized as a CUSO Technology (First Line of Defense) document that is updated and maintained by the CUSO Technology function. This Standard is owned by the Santander US Chief Information Security Officer ("CISO") and is approved by the Santander US Head of Technology and Operations ("T&O"). This Standard is reviewed and endorsed by Subsidiary standard owners.

This Standard is reviewed annually or when a material change to the operating environment, potential changes to regulations and contractual requirements, potential findings, or requested policies exceptions necessitate an out of cycle review.

2. GOVERNANCE AND ACCOUNTABILITY

2.1 Standard Governance

The Santander US CISO will:

- Own and author, review, oversee implementation of, and monitor compliance with the Standard.

The Subsidiary standard owners will:

- Review and endorse this Standard.

The CUSO Technology and Operations Executive Working Group (“T&O EWG”) will:

- Review and recommend approval of the Standard to the Santander US Head of T&O.

The Santander US Head of T&O will:

- Approve the Standard.

3. ROLES AND RESPONSIBILITIES

CUSO utilizes a three lines of defense ("LoD") model for risk management, with separately defined and segregated responsibilities consistent with applicable regulations and guidance.

First Line of Defense – Risk Management

First line of defense ("1LoD") units have accountability for the primary management of the risks that emanate from their activities. 1LoD units own, identify, measure, control, monitor and report all risks that are originated through activities such as business origination, the development, marketing or distribution of products, client maintenance, or operational or technological processes supporting customer activity.

Technology is the 1LoD unit accountable for owning, authoring, reviewing, overseeing implementation of, and monitoring compliance with this Standard. Accountabilities of individual functional areas within Technology are defined in Section 4.

Second Line of Defense – Risk Control

The **Risk** function is a second line of defense ("2LoD") unit that defines risk management frameworks and policies, independently monitors risk exposures, implements comprehensive and appropriate risk controls, and reviews and challenges 1LoD units on their activities to help ensure that risk is managed in line with the agreed frameworks and Risk Appetite levels. The Risk function is organized by risk type (e.g., Enterprise Risk Management ("ERM"), Compliance, Credit, Market, Liquidity, Operational, and Model Risk) and other specialized functions (Risk Analytics) at the CUSO and Subsidiary levels. The ERM function administers Risk Governance & Reporting, Material Risk Program, Strategic Risk, Climate Risk, New Product & Business Activities, and Risk Appetite programs. The Second LoD takes primary responsibility for designing and documenting comprehensive enterprise-wide risk management framework that meets regulatory guidelines and is commensurate with the size, complexity, and risk profile of the covered subsidiaries and will be held accountable by the Chief Executive Officer ("CEO") and the Board.

Third Line of Defense – Risk Assurance

Internal Audit is independent of any other function or unit in CUSO and provides independent assurance to the Board and senior management by assessing the quality and effectiveness of the processes and systems of internal control, risk management and risk governance, compliance with applicable regulations, and the reliability and integrity of financial and operational information.

4. STANDARD

4.1 Standard Overview

This Standard defines the minimum mandatory security requirements for Corporate Device builds and configuration. The following list specifies the devices considered "in-scope" for this standard:

- **Corporate Devices:** Devices managed by Santander or on behalf of Santander, to access to Santander information systems. For the purpose of this standard, Corporate Devices scope includes:
  - **Corporate End-User Device:** Workstations and portable devices (including mobile devices) provided by Santander to users for carrying out their work
  - Servers, including Operating System ("OS"), network devices, security devices, hypervisors and databases
  - ATMs
- Servers, including Operating System ("OS"), network devices, security devices, hypervisors and databases, Storage services, hosted on managed datacenters or on third party cloud service providers.

4.2 Standard Requirements

The following requirements and objectives must be considered for activities that support Build and Configuration Management at CUSO. Security control requirements include all applications, whether the institution acquires or develops them.

4.2.1 Lifecycle Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.1.1	s-CISO	CUSO must define security requirements for how in-scope devices are configured and built, in alignment with Information Security Standards and industry standards (when available).
SUS.SBS.4.2.1.2	Santander US Head of Infrastructure	CUSO must create and maintain documentation that specify build and/or configuration settings for in-scope devices and services in alignment with security requirements.
SUS.SBS.4.2.1.3	Information Technology and Operations ("T&O") GRC	Hardening guides that define build and configuration settings must be approved both by the Head of Infrastructure and the s-CISO.
SUS.SBS.4.2.1.4	Santander US Head of Infrastructure	CUSO must design and implement a process to configure in-scope devices in accordance with the hardening guides before devices are deployed for both production and pre-production environments.

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.1.5	s-CISO	CUSO must implement a monitoring program for security related configuration settings defined in the hardening guides. In-scope devices and services must be checked and enforced for security configuration compliance on at least a quarterly basis, or higher based on the criticality of the asset.
SUS.SBS.4.2.1.6	s-CISO	CUSO must implement an approval process for exceptions to the security related configuration settings defined in the hardening guides.
SUS.SBS.4.2.1.7	s-CISO	Users must be configured and managed in compliance with the *CUSO Identity and Access Management Standard.*
SUS.SBS.4.2.1.9	s-CISO	Secure configurations must include enabling logging following the *CUSO Logging and Monitoring Standard.*

4.2.2 Standard Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.2.1	s-CISO	**All in-scope devices** Hardening guides must include controls to the configuration or installation options of each technology in order to comply with defined mandatory security controls. These configurations can be set up as Policy as Code statements as available.
SUS.SBS.4.2.2.2	s-CISO	**All in-scope devices** Secure remote administration must be encrypted and leverage protocols and encryption keys in compliance with the *CUSO Encryption and Data Masking Standard.*
SUS.SBS.4.2.2.33	s-CISO	All in-scope devices and services must be configured in accordance with the principle of least functionality. Unnecessary or non-essential services, ports, protocols, and software must be disabled or removed based on approved hardening guides. Any deviations must be formally approved and managed in accordance with the exception governance process.
SUS.SBS.4.2.2.3	s-CISO	**End-user devices and Automated Teller Machines ("ATMs")** End-user devices must be configured to avoid booting from removable media devices.
SUS.SBS.4.2.2.4	s-CISO	**End-user devices and ATMs** Basic Input/Output System ("BIOS") / Unified Extensible Firmware Interface ("UEFI") must be password protected.
SUS.SBS.4.2.2.5	s-CISO	**End-user devices** End-users must not have administrative privileges to the operating system or the BIOS/UEFI on any corporate end-user device.
SUS.SBS.4.2.2.6	s-CISO	**End-user devices** Devices must automatically lock the screen of the user session after 10 minutes or less of idle time. The user must re-authenticate to unlock the screen.
SUS.SBS.4.2.2.31	s-CISO	Corporate End User Devices must be managed through centralized management solutions.

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.2.32	s-CISO	For Corporate Mobile Devices, CUSO must define a process to provide application sources. Alternative stores are not permitted. Santander must have the ability to block and remove any applications deemed malicious.
SUS.SBS.4.2.2.7	s-CISO	**Laptops and Mobile** Portable devices must be encrypted. Cryptographic keys required to decrypt the data that is stored on the device in encrypted form must be password protected.
SUS.SBS.4.2.2.8	s-CISO	**Laptops** Virtual Private Network ("VPN") on laptops must be configured to force a corporate VPN connection when connected to a non-corporate network. Split tunneling between corporate and non-corporate networks must be prohibited unless explicitly allowed by s-CISO.
SUS.SBS.4.2.2.9	s-CISO	**Removable Media** Read and write access on removable Media (Universal Serial Bus ("USB")) is not allowed by default. Exceptions are registered and temporary requests disabled upon expiry of the request.
SUS.SBS.4.2.2.10	s-CISO	**Removable Media** Read or write access on removable media devices must be authorized by s-CISO and only enabled on those corporate workstations or laptops supporting encrypted USB. All devices must be encrypted using CUSO approved methods as defined by the *CUSO Encryption and Data Masking Standard.*
SUS.SBS.4.2.2.11	s-CISO	**Removable Media** Portable physical storage media containing CUSO data or non-public information, as per *CUSO Data and Information Protection Standard,* must be encrypted.

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.2.12	s-CISO	**Corporate Mobile Devices** Personal codes (Personal Identification Number (“PINs”)) or biometric controls (e.g., fingerprint, face recognition) used to block / unblock devices are allowed provided that: • Separate authentication is in place to access Santander information in compliance with the *CUSO Authentication and Authorization Standard* • Device is reset and all Santander information is erased after 10 failed attempts • Device management tools are in place to remotely wipe out the device
SUS.SBS.4.2.2.13	s-CISO	**Corporate Mobile Devices** Geolocation services must be used to support device recovery efforts.
SUS.SBS.4.2.2.14	s-CISO	**Corporate Mobile Devices** Application sandboxing must be implemented through the use of secure containers with internal boundaries to limit the access and functionality of executed code.
SUS.SBS.4.2.2.15	s-CISO	**Corporate Mobile Devices** Mobile devices must automatically lock the screen of the user session after one (1) minute or less of idle time. The user must re-authenticate to unlock the screen.

4.2.3 Implementation Process Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.3.1	Santander US Head of Infrastructure	Secure configurations must include testing the in-scope devices and services to confirm that they are securely configured prior to operational use.
SUS.SBS.4.2.3.2	Santander US Head of Infrastructure	Only Santander-approved software must be installed on Santander computing devices.

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.3.3	Santander US Head of Infrastructure	Only authorized Technology workforce members within a subsidiary must install or delegate installation of software or make configuration changes to Technology assets owned by the subsidiary in accordance with the *CUSO Identity and Access Management Standard*.
SUS.SBS.4.2.3.4	Santander US Head of Infrastructure	Secure configurations must include removing, changing or disabling all default accounts, and changing default passwords for accounts that cannot be removed or disabled.
SUS.SBS.4.2.3.5	Santander US Head of Infrastructure	All relevant security patches, as defined by the *CUSO Vulnerability and Patch Management Standard*, must be installed on corporate devices immediately following deployment, in accordance with defined patching timelines.
SUS.SBS.4.2.3.6	Santander US Head of Infrastructure	Installing obsolete software, as defined by the availability of security patches, is prohibited. Any exception to this requirement must be documented, risk-assessed, and approved by the Santander US CISO or delegate.
SUS.SBS.4.2.3.7	Santander US Head of Infrastructure	A process must be implemented to periodically review and approve changes to the configuration and versions of information security tools deployed with the standard device images, including anti-virus/anti-malware, VPN and encryption agents.

4.2.4 Device Management Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.4.1	Santander US Head of Infrastructure	When a portable device is lost or stolen, an instruction must be issued to remotely wipe the device.
SUS.SBS.4.2.4.2	s-CISO	When a portable device is lost or stolen, remote connection from that device to the CUSO network must be disabled. In addition, the loss or theft must be immediately reported to the Cyber Fusion Center (“CFC”).
	Santander US Head of Infrastructure	
SUS.SBS.4.2.4.3	Santander US Head of Infrastructure	When an end-user device is transferred from one user to another, it must first be wiped or re-imaged.
SUS.SBS.4.2.4.4	Santander US CISO	Laptop certificates must be configured to expire after six (6) months.

4.2.5 Policy as Code Requirements

Requirement ID	Accountable Role / Function	Requirement
SUS.SBS.4.2.5.1	s-CISO	For cloud deployments within Santander US public cloud landing zone, Policy as Code must be deployed (as an alternative to manual configuration hardening) to validate that the configuration of cloud services meets the predefined configuration and default deployment of asset types.
SUS.SBS.4.2.5.2	s-CISO	Policy as Code must be managed using the Software Development Lifecycle for software. Changes must be approved in the Change Management process.

5. REPORTING STRUCTURE AND ESCALATION

As part of an overarching risk assessment and reporting program, CUSO must conduct regular self-assessments to measure design adequacy and operating effectiveness of controls specified in this Standard. The results must be incorporated into risk reporting provided to the CUSO 2LoD functions, and to the Board, if applicable, in accordance with 2LoD function governance requirements.

6. EXCEPTIONS

Standard exceptions are expected to be infrequent but may be granted to address specific business needs. Subsidiary-specific exceptions require review and approval from both the s-CISO and the Santander US CISO. All approved Subsidiary-specific exemptions are listed in the table below.

Any additional material exceptions not explicitly defined in this section must include documented rationale, an assessment of associated risks (where applicable), and any other relevant details. These exceptions must be reviewed and approved during the Security Exceptions Function ("SEF") meeting.

Subsidiary:	Exceptions:
SBNA:	• No exceptions
BSNY:	• SUS.SBS.4.2.2.3 and SUS.SBS.4.2.2.4 as BSNY has no ATMs.
SanCap:	• SUS.SBS.4.2.2.3 and SUS.SBS.4.2.2.4 as SanCap has no ATMs.
SC:	• SUS.SBS.4.2.2.3 and SUS.SBS.4.2.2.4 as SC has no ATMs.
BSI:	• SUS.SBS.4.2.2.3 and SUS.SBS.4.2.2.4 as BSI has no ATMs.

7. DOCUMENT HISTORY AND VERSION CONTROL

7.1 Ownership and Authorship

Version	Author	Owner	Change
1.0	Santander US Information Security	Santander US CISO	Initial Version
2.0	Santander US Information Security	Santander US CISO	2020 Annual Update
3.0	Santander US Information Security	Santander US CISO	2021 Annual Update
4.0	Santander US Information Security	Santander US CISO	Off-Cycle Audit Update
5.0	Santander US Information Security	Santander US CISO	2022 Annual Update
6.0	Santander US Information Security	Santander US CISO	2023 Annual Update
6.1	Santander US Information Security	Santander US CISO	2024 Annual Update
7.0	Santander US Information Security	Santander US CISO	2025 Off Cyle Update to align with group's cybersecurity policies
8.0	CUSO Information Security	Santander US CISO	2025 Annual Update

7.2 Sign Off

Approver	Action	Date
Santander US Head of T&O	Approve	07/28/2026

7.3 Subsidiary Sign Off

Approving Body	Governance Committee Approval or Endorsement	Final Approval Date
Santander US CISO	Endorsement	07/22/2026
Santander Bank NA (“SBNA”) CISO	Endorsement	05/08/2026
Santander US Auto Chief Information Officer (“CIO”)	Endorsement	07/21/2026
BSI CIO	Endorsement	07/23/2026
Santander US Corporate and Investment Banking (“CIB”) CIO	Endorsement	07/28/2026

8 APPENDIX

8.1 Appendix A – Key Contacts

Title	Role	Name and Contact
Santander US Head of T&O	CUSO Technology	Patryk Nowakowski (patryk.nowakowski@santander.us)
Santander US CISO	CUSO Information Security	Alberto Hernandez (Alberto.Hernandez@santander.us)
Director, Information Security	CUSO Information Security	Jorge Lobo Cruz (jorge.lobo@santander.us)
SBNA CISO	CUSO Information Security	Andre Salgado (andre.salgado@santander.us)
Santander US Auto CIO	CUSO Technology	Bobby Mehra (Bobby.Mehra@santander.us)
SC CISO	CUSO Information Security	Rebecca Smith (rebecca.smith@santander.us)
BSI CIO	Banco Santander International Technology	Jose Oliveros (joliveros@bpi-gruposantander.com)
Sr. Director, Information Security	Banco Santander International Technology	Dayam Borges (dborges@bpi-gruposantander.com)
Santander US CIB CIO	CUSO Capital Markets, LLC/Banco Santander New York Technology	Xavier Jean Courtois (xavier.courtois@santander.us)
CIB CISO	CUSO Capital Markets, LLC/Banco Santander New York Technology	Frank Hsieh (frank.hsieh@santander.us)

8.2 Appendix B – Regulatory Obligations Addressed by this Standard

The following are the primary regulations addressed by CUSO Technology Standards:

- GLBA 501(b) - Interagency Guidelines Establishing Standards for Safeguarding Customer Information

- GLBA 501(b) - Interagency Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice

In addition, CUSO considered the following supervisory sources in developing Standards and in its ongoing assessment and oversight of risk:

- Federal Financial institutions Examination Council ("FFIEC") IT Handbook, including:
  - Information Security Booklet
  - Development and Acquisition Booklet
  - Architecture, Infrastructure, and Operations Booklet
  - Management Booklet
  - Outsourcing Technology Booklet
  - Supervision of Technology Service Providers Booklet
  - Business Continuity Management Booklet
- Office of the Comptroller of the Currency ("OCC") Model Risk Management booklet of the Comptroller's Handbook
- US Securities and Exchange Commission 2017-02 Guidance Update (Robo Advisers)
- National Institute of Standards and Technology ("NIST") Artificial Intelligence Risk Management Framework (AI RMF 1.0)
- International Standards Organization ("ISO") ISO/IEC 38507:2022 Information Technology — Governance of IT — Governance implications of the use of Artificial Intelligence by organizations
- The National Cyber Security Centre ("NCSC") Guidelines
- Personal Data Protection Commission Singapore ("PDPC") Model
- Monetary Authority of Singapore

8.3 Appendix C – Glossary

Term	Definition
Corporate Devices	Devices managed by Santander or on behalf of Santander, to access to Santander information systems. For the purpose of this policy Corporate Devices scope includes: • **Corporate End User Device:** Workstations and mobile devices provided by Santander to users for carrying out their work • Servers including OS and network services (e.g., Lightweight Directory Access Protocol ("LDAP"), Active Directory ("AD"), web, was), hypervisors, databases, network devices and perimeter security elements
Corporate End User Device	Workstations and portable devices provided by Santander to users for carrying out their work.
Mobile Device	Devices that are small enough to hold and are a smartphone or tablet.

Term	Definition
Policy as Code	Policy-as-code is an approach to policy management in which policies, controls are defined, updated, shared, and enforced using code. By leveraging code-based automation instead of relying on manual processes to manage policies, policy-as-code allows teams to enforce automated compliance with policies and reduce the potential for mistakes due to human error. Policy as Code must be managed using the Software Development Lifecycle and changes must be approved via the Change Management process.
Portable Device	Devices that can be easily carried including Laptops and Mobile Devices.
s-CISO	The executive accountable for managing the Information Security function at a specific subsidiary.
Server	Servers including OS and network services (e.g., LDAP, AD, web, was), hypervisors, databases, network devices and perimeter security elements.
Removable Media Device	Any type of portable and storage devices that can be connected or removed from other devices in order to transfer, store or use data while the system is running.

8.4 Appendix D – Related Policies and Process and Administrative Documents

Document Type	Subsidiary / Department	Owner	Title
Policy	CUSO Operational Risk Management	Santander US Chief Operational Risk Officer	CUSO Information Risk Management Enterprise Policy
Policy	CUSO Technology	Santander US CISO	CUSO Information Security Operating Policy
Standard	CUSO Technology	Santander US CISO	CUSO Data and Information Protection Standard
Standard	CUSO Technology	Santander US CISO	CUSO Vulnerability and Patch Management Standard
Standard	CUSO Technology	Santander US CISO	CUSO Identity and Access Management Standard
Standard	CUSO Technology	Santander US CISO	CUSO Authentication and Authorization Standard
Standard	CUSO Technology	Santander US CISO	CUSO Virus and Malware Protection Standard
Standard	CUSO Technology	Santander US Head of Infrastructure	CUSO Technology Change and Release Management Standard
Standard	CUSO Technology	Santander US T&O Chief Operating Officer	CUSO Enterprise Project Management Office Standard